Individual Contribution Statement - Nguyen Vo Thanh Tu

Course	Introduction to Information Security 2026-2027
Class / Group	N05 / Group 05
Name	Nguyen Vo Thanh Tu
Student ID	523H0189
Primary responsibility	Database security, testing and audit logging
Project	Design, Implement, and Audit Secure Access Control - University Records System (UniRecords)

1. Tasks completed

- **Database schema:** `database/schema.sql`, covering users, roles, sessions, student records, classes, enrollments, grades with four components and a generated total, password-reset requests and the audit log.
- **Least privilege:** a separate application role `uni_app`, created from an environment password (`database/init/00-create-roles.sh`), with table- and column-level grants, no DELETE on academic data and read-only policy tables.
- **Guard triggers:** grade writes limited to the assigned lecturer and blocked for self-grading, role-conflict checks, the class capacity limit (30), one lecturer per class, and lecturer-only assignment.
- **Audit logging:** an append-only `audit_logs` table with a SHA-256 hash chain, `audit_verify_chain()`, and the sanitised logging helper `source/app/audit.py`.
- **Deployment:** Docker Compose set-up, `.env.example`, and database and application ports bound to localhost.
- **Testing:** the automated suite of 58 tests (20 mandatory and 38 original) with per-test evidence traces, and the screenshot capture `tests/capture_screenshots.py`.
- **Report:** wrote Chapters 6 and 7 and Appendices A-C, and built the evidence index.
- **Demo video:** segment 3 (SQL injection and input validation, audit-log inspection, test results).

2. Repository commits

My commits are recorded in the group repository: **https://github.com/duongtranquockhanhwork/Project-for-user-roles** (commit author **Nguyen Vo Thanh Tu**). They can be listed with `git log --author="Nguyen Vo Thanh Tu" --date=short` or on the repository's *Commits* page. The first version of the project was imported into the repository by Duong Tran Quoc Khanh; my own commits follow in the repository history.

3. Technical decisions made

- **Audit ids, timestamps and hashes are assigned by a trigger under an advisory lock.** The client cannot choose them, and the chain order always matches the id order.
- **Successful changes are logged in the same transaction as the change; rejections in a separate one.** A denial is therefore recorded even though the request changes nothing.
- **The course total is a generated column** (10/20/20/50 %), so no client can write an inconsistent total.
- **The capacity trigger locks the class row** before counting, so concurrent enrollments cannot exceed 30 students.

- **Tests look up records by natural keys and create fresh users,** which makes the suite repeatable on any database state.

4. Problems solved

- **T42 (tamper detection) failed intermittently.** The tamper step sometimes wrote values identical to the original ones, so nothing actually changed. I changed it to always add a field to the entry, which makes the detection deterministic.
- **T24 (session fixation) raised a cookie conflict** because the planted cookie and the issued cookie had different domains. I compared the token from the response's Set-Cookie header instead.
- **T35 used a payload longer than the 50-character search limit,** so it was rejected by validation (400) before reaching the query. I shortened the payload so that the test really exercises the parameterized search.
- **Running a single test file overwrote the full evidence table.** The documented procedure is now to always run the complete suite before capturing evidence.

5. Approximate hours worked

[to be filled] hours in total (week 1: [ ] h, week 2: [ ] h, week 3: [ ] h).

6. Contributions of the other members

- **Trieu Ngoc Van Anh** produced the threat model, the DFD, the security requirements, the access-control matrix and policy, and the remaining-risk review, and wrote report Chapters 1, 3, 4 and 8.
- **Duong Tran Quoc Khanh** implemented authentication, sessions and CSRF, the authorization layer, the application features and user interface, and account self-service with password reset, and wrote report Chapters 2 and 5.

7. Review of the complete submission

I reviewed the complete submission (source code, database scripts, tests, evidence, report and demo video) and agree with its content.

Date: ____ / ____ / 2026

Signature: _____

Nguyen Vo Thanh Tu (523H0189)